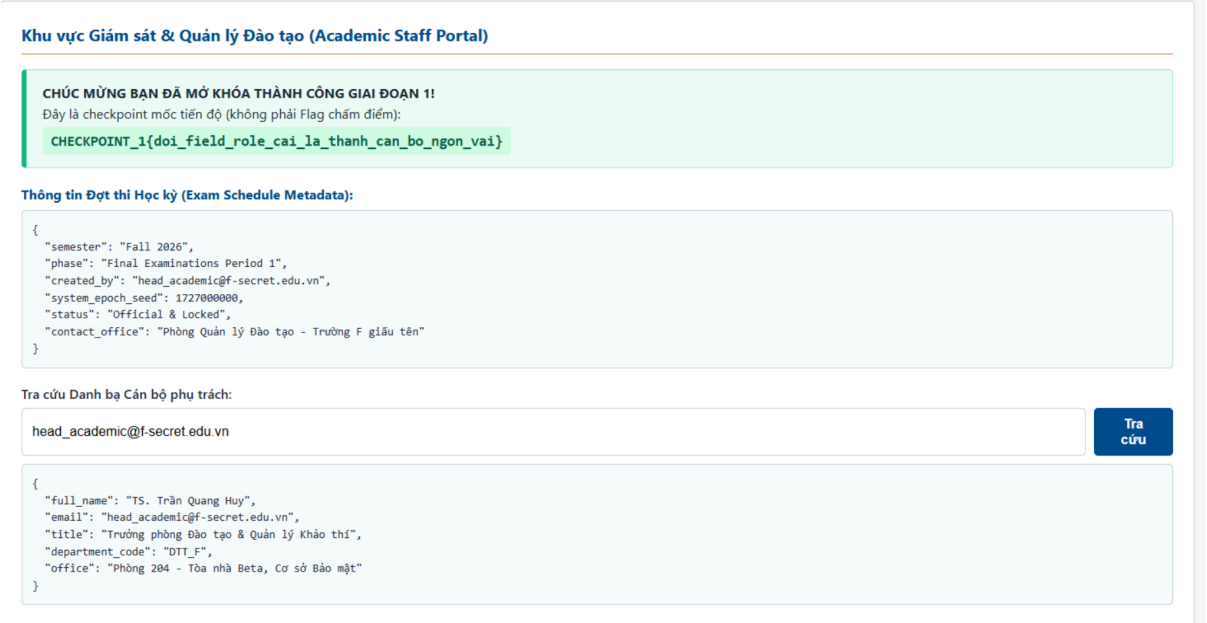
Câu 1:

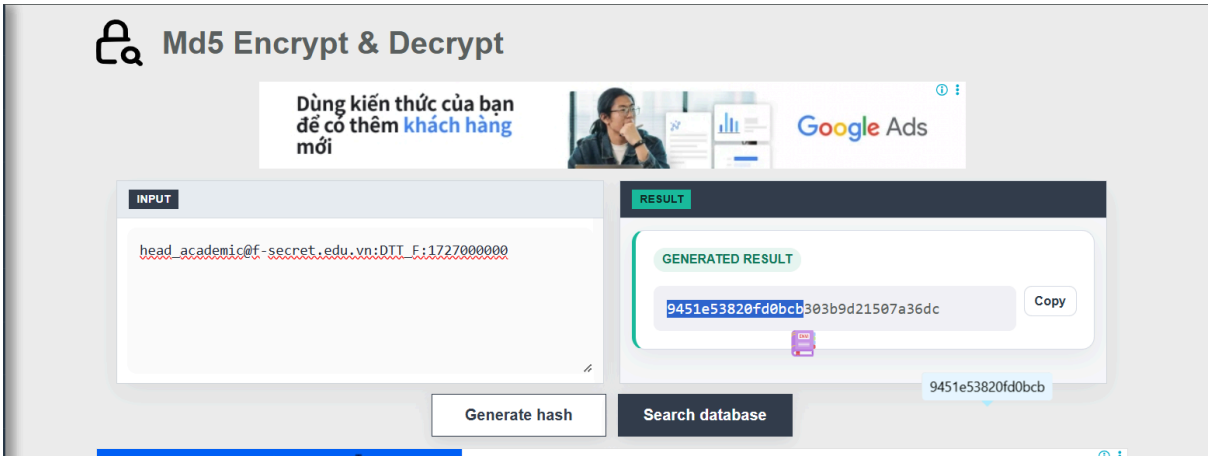
-Ban đầu, em có đăng nhập vào với tài khoản sinh viên sẵn có. Tuy nhiên ở đây, khu vực này chỉ hiển thị cho **cán bộ** => nên em nghĩ tới đổi role

-Em bật Intercept on, login và sửa request từ role "**student**" => "**academic_officer**" => có checkpoint1 và bảng thông tin:



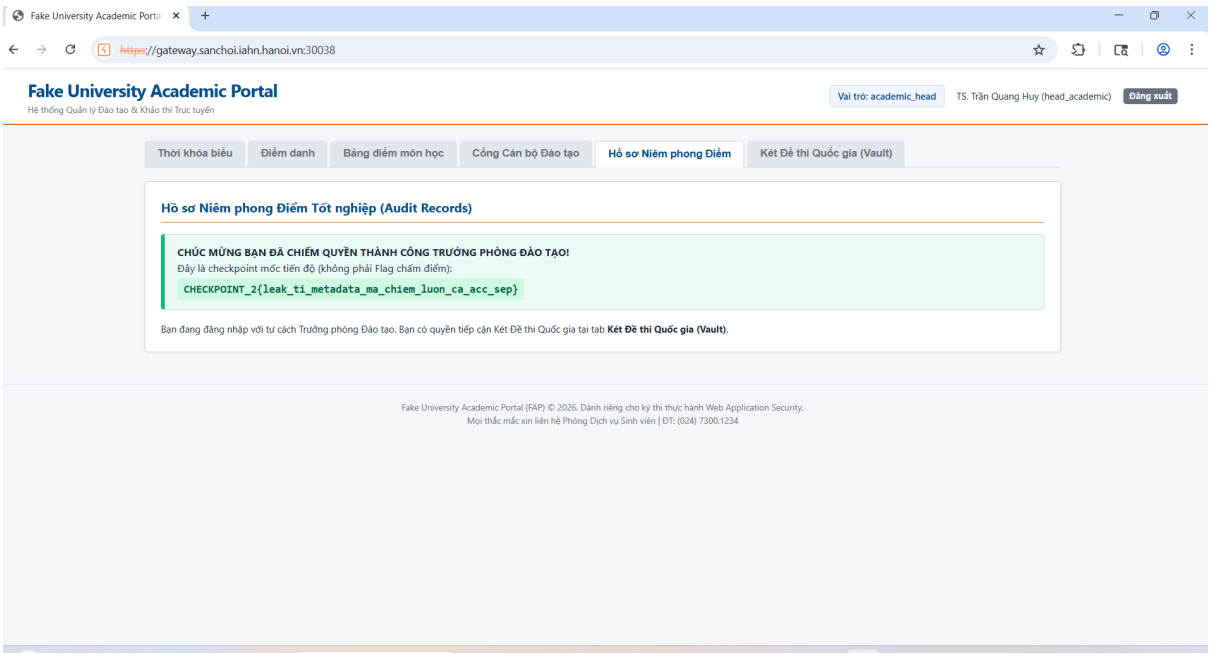
Câu 2:

Như đề bài yêu cầu thì ta cần xâu chuỗi các **nguồn dữ liệu học kỳ** và **hồ sơ cán bộ** vào với nhau. Ở đây thầy có hint là **md5**, nên em có thử vài cách để băm mà k được. Nay được thầy hint thêm nên em có làm theo hướng dẫn:



(ở đây theo như em tìm hiểu là: identity + scope + time/nonce là 3 thành phần kinh điển của mọi token xác thực)

=> em lấy 16 ký tự đầu tiên và được Checkpoin2:



Câu 3:

Khi PIN sai lần đầu “000000“ => "Mã Master PIN không chính xác" => auth đã pass
=Thu hẹp scope

-Nhờ hint “**độ trễ mạng**” nên em có nghĩ tới sự chênh lệch về thời gian phản hồi như hôm trước có nói với thầy
Giả dụ thử: 1,2,3
1 -sai => 3ms
2 -đúng => 50ms
3 -sai =>2ms
=> tức là ở đây nếu ký tự đúng sẽ tốn nhiều tgian hơn để phản hồi so với ký tự sai

-Tuy nhiên thì em có nhờ AI code và em thấy độ trễ chưa có gì quá khác biệt

-Dựa vào **writeup** của thầy nên em có thử nhiều đoạn code và cho chạy để ktra độ trễ
+Em cho cỡ **7 request/ 1 ký tự**. Vì thấy không có tiền triển tốt và khả năng chênh lệch về độ trễ => Em cho mỗi vị trí chạy **4 vòng**: **5 → 15 → 25 → 50 request**, lấy **Top 5**, rồi tổng hợp để chọn ký tự có tiềm năng ổn định nhất
Em có bảng:

```
SO SANH CAC VONG
================================================================================
CHAR  TOP5    AVG RANK    AVG MEDIAN     MEDIANS
--------------------------------------------------------------------------------
9     3/4     3.00        58.20          61.3, 56.7, 56.5
7     2/4     3.00        58.87          61.3, 56.5
5     2/4     4.00        58.12          59.3, 56.9
B     1/4     1.00        71.28          71.3
Q     1/4     1.00        65.70          65.7
S     1/4     1.00        57.70          57.7
A     1/4     2.00        66.24          66.2
P     1/4     2.00        60.32          60.3
3     1/4     2.00        56.96          57.0
1     1/4     3.00        61.46          61.5
L     1/4     3.00        60.77          60.8
R     1/4     3.00        58.33          58.3
D     1/4     4.00        60.57          60.6
0     1/4     5.00        60.45          60.4
```

=> Vẫn sai

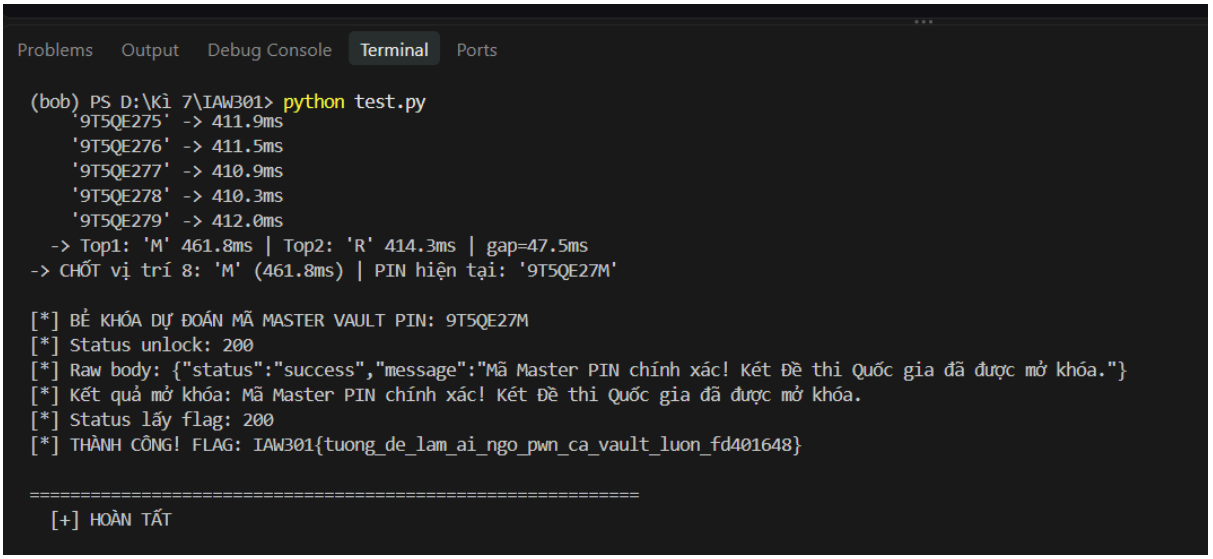
=Em thử để cố định **request là 20**, so sánh **gap giữa top 1 và 2** để tin là **tín hiệu thật**. Và vì rút kinh nghiệm từ những code cũ em đã chạy nên code mới tgian sẽ tăng dần (**do sleep cộng dồn, nếu không tăng đều là dấu hiệu cần nghi ngờ tiếp**)

=> Final Flag:

Response

Pretty Raw Hex Render

```
1 HTTP/1.1 200 OK
2 Content-Length : 352
3 Content-Type : application/json
4 Date : Mon, 28 Sep 2026 20:00:18 GMT
5 Server : uvicorn
6
7 {
  "status" :"success" ,
  "package_name" :"Đề thi Quốc gia Mật - Môn IAW301 (An toàn Ứng dụng Web)" ,
  "verified_by_pin" :"9T5QE27M" ,
  "flag" :"IAW301{tuong_de_lam_ai_ngo_pwn_ca_vault_luon_fd401648}" ,
  "message" :
  "XUẤT SẮC! Bạn đã sử dụng kỹ thuật Timing Side-Channel để bẻ khóa thành công K
  ét Đề thi và nhận được Flag!"
}
```


Problems
Output
Debug Console
Terminal
Ports
(bob) PS D:\Kì 7\IAW301> python test.py
'9T5QE275' -> 411.9ms
'9T5QE276' -> 411.5ms
'9T5QE277' -> 410.9ms
'9T5QE278' -> 410.3ms
'9T5QE279' -> 412.0ms
-> Top1: 'M' 461.8ms | Top2: 'R' 414.3ms | gap=47.5ms
-> CHỐT vị trí 8: 'M' (461.8ms) | PIN hiện tại: '9T5QE27M'
[*] BẺ KHÓA DỰ ĐOÁN MÃ MASTER VAULT PIN: 9T5QE27M
[*] Status unlock: 200
[*] Raw body: {"status":"success","message":"Mã Master PIN chính xác! Két Đề thi Quốc gia đã được mở khóa."}
[*] Kết quả mở khóa: Mã Master PIN chính xác! Két Đề thi Quốc gia đã được mở khóa.
[*] Status lấy flag: 200
[*] THÀNH CÔNG! FLAG: IAW301{tuong_de_lam_ai_ngo_pwn_ca_vault_luon_fd401648}
[+] HOÀN TẤT